UNIVERSIDAD DEL VALLE
FACULTAD DE INGENIERÍA — ESCUELA DE SISTEMAS
MAESTRÍA EN DESARROLLO DE APLICACIONES INTELIGENTES
SEGURIDAD EN EL DESARROLLO DE APLICACIONES · MÓDULO DOS

Punto 4. Aportes normativos específicos y brechas de cobertura

Taller 2. Marcos de trabajo de ciberseguridad · FinanCali S.A.S.

Miguel Ángel Rincón — 2502619-7729
Maria Paula Jimenez I — 2507713-7729
David Steven Duran Vallejo — 2508228-7729

> Este documento desarrolla de forma exclusiva el Punto 4. Parte del caso de uso, de la estimación de madurez y del panorama normativo fijados en el Taller 1, y de la selección de NIST CSF 2.0 hecha en el Punto 2. No reabre la comparación entre marcos ni desarrolla el Punto 3.

4.1. Objeto y criterio de lectura

El Módulo Dos pide identificar qué elementos del sistema de scoring escapan al marco de ciberseguridad seleccionado, distinguir cuáles de ellos quedan atendidos por los marcos normativos de inteligencia artificial ya identificados y cuáles permanecen sin cobertura, y argumentar por qué la protección del sistema exige los dos tipos de referente. La respuesta se construye sobre hechos ya documentados, no sobre un catálogo genérico de riesgos de la IA.

Esos hechos son los siguientes. FinanCali es una fintech colombiana de unos 50 empleados, sin área de seguridad ni rol de gobernanza de IA, que origina crédito de consumo por canales web y móvil. El caso de uso produce un score de 0 a 100 con un modelo supervisado de datos tabulares, entrenado por lotes y sin reentrenamiento automático en producción. El motor aprueba o rechaza los extremos y envía la franja intermedia a un analista. Las variables incluyen ingresos, historial crediticio, antigüedad laboral, endeudamiento y comportamiento de pago, tomadas de la declaración del solicitante, del historial interno y de centrales de riesgo. El servicio es un microservicio en la nube, expuesto por una API REST interna. Se conservan la solicitud, las variables y el score para auditoría. El volumen es de cientos de solicitudes diarias. La operación del escenario base se financia con recursos propios y no está, por ese solo hecho, bajo vigilancia de la Superintendencia Financiera de Colombia. El modelo puede ser interno o adquirido, y la infraestructura puede estar por fuera del país.

Se usan dos juicios distintos, y conviene no mezclarlos. Un elemento está **atendido** cuando un referente del Taller 1 formula un deber o un resultado que lo cubre. Eso no afirma que FinanCali ya lo practique: la madurez inicial muestra lo contrario en varios puntos. Un elemento **permanece sin cobertura adecuada** cuando, sumados el CSF 2.0 y esos referentes, ninguno fija una exigencia lo bastante específica para proteger este sistema en ese punto. La deuda de adopción se cierra ejerciendo un referente que ya se tiene. La brecha de cobertura no se cierra adoptando otro marco del mismo nivel: exige una decisión de diseño especializada.

4.2. Límite de NIST CSF 2.0 en este caso

NIST CSF 2.0 sigue siendo el marco pertinente para la capa que el Punto 2 le asignó: la gestión del riesgo de ciberseguridad de la organización y de la plataforma del scoring. El propio marco delimita esa capa. Al tratar las tecnologías emergentes, señala que la inteligencia artificial conlleva riesgos de ciberseguridad y de privacidad y,

además, otros riesgos, y remite esos otros riesgos al NIST AI RMF. En la misma línea, distingue la pérdida de confidencialidad, integridad y disponibilidad de los problemas que nacen del tratamiento mismo de los datos, entre ellos la discriminación y la pérdida económica, que no dependen de un incidente de ciberseguridad [1].

La tabla siguiente fija ese límite sobre componentes concretos del caso. Es representativa: muestra dónde el CSF sí responde a las brechas de madurez del Taller 1 y dónde su resultado, aunque se cumpla, deja intacto el problema del modelo.

Tabla 1. Resultados de NIST CSF 2.0 que sí alcanzan al scoring, y su límite

Resultado del CSF 2.0	Hecho del caso al que responde	Límite frente al modelo
Gobernar: política, roles y supervisión del riesgo de ciberseguridad (GV.PO, GV.RR, GV.OV)	Hoy no hay política formal ni comité; las decisiones las toma el equipo técnico.	Organiza la gobernanza de la ciberseguridad. No crea la rendición de cuentas por el comportamiento del score ni por su efecto sobre el solicitante.
Gobernar: riesgo de ciberseguridad de la cadena de suministro (GV.SC)	El flujo depende de centrales de riesgo, de un posible proveedor del modelo y de servicios de nube.	Fija expectativas de ciberseguridad hacia el tercero. No examina la equidad, la explicabilidad ni la base de datos de entrenamiento de un modelo adquirido.
Identificar: activos y riesgos (ID.AM, ID.RA)	El inventario de aplicación, API, bases, credenciales, modelo y nube es parcial.	El modelo entra como activo. Las variables no entran como factores cuya legitimidad para negar un crédito deba justificarse.
Proteger: acceso y seguridad de los datos (PR.AA, PR.DS)	Hay acceso privilegiado al conjunto de entrenamiento y tokens de integración con fuentes externas.	Reduce la adulteración, la pérdida y el acceso no autorizado. Un dato intacto puede seguir siendo incompleto, desactualizado o no representativo.
Detectar: monitoreo y análisis de eventos adversos (DE.CM, DE.AE)	No hay monitoreo de anomalías de la API ni del comportamiento del modelo; solo se observa la disponibilidad del servicio.	DE.CM puede cerrar el vacío de anomalías de seguridad. La deriva, el sesgo y la caída de desempeño no son, por sí solos, eventos adversos de ciberseguridad.
Responder y Recuperar (RS, RC)	No hay procedimiento documentado de respuesta ni de retorno a una versión anterior del modelo.	El retorno restaura el servicio. No dice cuándo una versión es inaceptable por equidad, ni qué hacer con un score construido sobre un dato negativo que ya debió salir de la central.

La misma frontera aparecería si el marco principal hubiera sido CIS Controls. Su fortaleza, reconocida en el Punto 2, está en las salvaguardas priorizadas sobre activos, identidades, configuración, vulnerabilidades y monitoreo técnico. Esas salvaguardas refuerzan la columna izquierda de la tabla. No miden la equidad de un score, no explican una decisión de crédito y no incorporan las reglas del habeas data financiero. La conclusión de este punto no depende, por tanto, de revertir la selección: CIS Controls permanece como complemento técnico de la plataforma, que es el papel que el Punto 2 ya le reservó.

4.3. Elementos que escapan al CSF y referente que los atiende

Los siete elementos siguientes salen de las dimensiones del caso de uso y de las brechas de madurez. En cada uno se indica el referente del Taller 1 que lo atiende y el alcance real de esa atención. Los identificadores B1 a B7 anticipan las brechas de la sección 4.4, para que un elemento pueda estar atendido en el nivel del resultado y, aun así, dejar una decisión sin especificar.

Tabla 2. Elementos del scoring que escapan a NIST CSF 2.0

Elemento	Hecho del caso que lo activa	Por qué el CSF 2.0 no lo cubre	Referente del Taller 1 que lo atiende
E1. Gobernanza del ciclo de vida del modelo	No existe rol ni comité de gobernanza de IA. El modelo está en producción y las decisiones sobre él son ad hoc.	GV asigna responsables del riesgo de ciberseguridad, no del ciclo de entrenamiento, validación, aprobación y retiro del modelo.	NIST AI RMF 1.0, función GOVERN; ISO/IEC 42001 como sistema de gestión; ISO/IEC 23894 como guía de riesgo. El CONPES 4144, eje de ética y gobernanza, solo como política pública [2] [3] [4] [5].
E2. Monitoreo del comportamiento del modelo	Se vigila la disponibilidad. No hay seguimiento de deriva ni de sesgo. El modelo no se reentrena solo, así que el deterioro no se corrige por inercia.	DE.CM observa el entorno tecnológico en busca de eventos de ciberseguridad. Un score que empeora puede producirse con la API sana y el servicio disponible.	AI RMF, MEASURE 2.11 y MEASURE 3.1, que piden evaluar equidad y sesgo y seguir los riesgos a lo largo del tiempo; ISO/IEC 42001, en la gestión del ciclo de vida del sistema; ISO/IEC 23894, en el tratamiento del riesgo [2] [3] [4].
E3. Equidad de la decisión automática	La población afectada son personas naturales de distintos perfiles socioeconómicos. Ingresos, antigüedad laboral y endeudamiento participan en un rechazo que, en los extremos, nadie revisa.	El CSF no caracteriza impactos sobre grupos de personas. La discriminación y la pérdida económica por el tratamiento están, en su propio texto, fuera del incidente de ciberseguridad [1].	AI RMF, caracterización de impactos en MAP y MEASURE 2.11. La Circular Externa 002 de 2024 incluye los sesgos humanos y las fallas de diseño entre las contingencias del sistema de administración de riesgos. El CONPES 4144, eje de mitigación de riesgos, orienta la política y no fija un umbral. Queda abierta B2 [2] [6] [5].
E4. Explicación del score	La salida es un número de 0 a 100 producido por un modelo de boosting sobre datos tabulares. El solicitante solo ve el canal web o móvil. El analista interviene en la franja intermedia.	Ninguna función del CSF exige que el resultado de un modelo sea interpretable para quien decide ni comprensible para quien soporta la decisión.	AI RMF, MEASURE 2.9: explicar, validar y documentar el modelo e interpretar la salida en su contexto. Circular 002 de 2024, numeral VII: información sobre el tratamiento. Ley 1581 de 2012, principio de transparencia. La explicación escrita de las razones del rechazo, en la Ley 1266, tiene un destinatario más estrecho: ver B3 [2] [6] [7] [8].
E5. Proporcionalidad, calidad e impacto de privacidad	Se tratan datos personales, financieros y crediticios identificables, con posibilidad de inferir información socioeconómica, para una decisión que condiciona el acceso al crédito.	PR.DS protege confidencialidad, integridad y disponibilidad. No aplica el juicio de idoneidad, necesidad, razonabilidad y proporcionalidad, ni ordena un estudio de impacto previo al diseño.	Circular 002 de 2024, numerales I, III, IV, V y X; principios de la Ley 1581 de 2012; AI RMF, MEASURE 2.10. El numeral VIII de la circular, limitado a medidas de seguridad del dato, sí se apoya en el CSF: es zona de solapamiento, no aporte exclusivo. Queda abierta B6 [6] [7] [2].
E6. Supervisión humana de la decisión semiautónoma	Hay un analista en la franja intermedia y un flujo manual si el servicio cae. Los extremos se deciden solos. El equipo es reducido y el volumen es de cientos de solicitudes al día.	El CSF no diseña la frontera entre la decisión automática y la revisión humana, ni la autoridad para revocar un score.	AI RMF, al establecer el contexto de uso y los impactos sobre las personas, e ISO/IEC 42001, en el uso responsable del sistema. El Reglamento (UE) 2024/1689 serviría de contraste si el sistema entrara en su ámbito, y hoy no entra. Queda abierta B4 [2] [3] [9].
E7. Reglas de habeas data sobre la lógica y la vigencia del score	Cada solicitud consulta centrales de riesgo. El score se conserva, junto con las variables que lo produjeron, para auditoría interna.	Ninguna categoría del CSF prohíbe fundar el crédito solo en el incumplimiento reportado, ni ordena actualizar una medición cuando el dato negativo se retira.	Ley 1266 de 2008, modificada por la Ley 2157 de 2021: valoración concurrente y prohibición de decidir exclusivamente con el reporte negativo; actualización de la medición asociada al dato negativo; la consulta hecha por el titular no puede disminuir el score. Queda abierta B5 [8].

Alcance real de cada bloque normativo

La Circular Externa 002 de 2024 de la Superintendencia de Industria y Comercio es el referente colombiano que más directamente cubre el tratamiento de datos personales dentro del modelo. Exige ponderar idoneidad, necesidad, razonabilidad y proporcionalidad; administrar los riesgos de ese tratamiento, con mención expresa de sesgos humanos, fallas técnicas, vulnerabilidades de seguridad y fallas de diseño; documentar un estudio de impacto de privacidad antes del diseño cuando el alto riesgo para los titulares sea probable; usar datos veraces, completos, exactos, actualizados, comprobables y comprensibles; y disponer de medios demostrables para los derechos de los titulares [6]. El score de FinanCali incide en el acceso al crédito y se alimenta de datos identificables: el supuesto de alto riesgo del numeral IV se cumple con los hechos del caso. El estudio de impacto, por tanto, es deuda de adopción de un deber ya aplicable, no una brecha de cobertura. El sistema, además, ya está en producción, de modo que el estudio deja de ser una condición de diseño y pasa a ser una evaluación sobre un tratamiento que ya ocurre.

La Ley 1266 de 2008, en el texto que le da la Ley 2157 de 2021, cubre la lógica crediticia que ningún marco de ciberseguridad contiene. El usuario de la información debe valorarla de forma concurrente con otros factores que técnicamente incidan en el estudio de riesgo, y no puede decidir una solicitud apoyándose solo en el incumplimiento suministrado por el operador [8]. Esa regla alcanza a FinanCali en el escenario base, porque consulta centrales y decide crédito, con independencia de que la Superintendencia Financiera no la vigile. El parágrafo 3 del artículo 13 exige actualizar de manera simultánea la información negativa asociada a calificaciones o scorings cuando se retire el dato negativo o cese el hecho que disminuyó la medición. Por su ubicación, el parágrafo regula la permanencia en las bases de los operadores. Aun con esa lectura restrictiva, produce un efecto de diseño en FinanCali: las variables conservadas para auditoría no pueden reutilizarse en una decisión nueva, en un reentrenamiento o en el monitoreo como si el dato negativo siguiera vigente. El parágrafo 2 del artículo 10 añade un límite de features: la consulta del historial por el propio titular no puede disminuir el score. Conviene verificar que el diccionario de variables no esté usando el número de consultas como proxy del historial crediticio.

Hay una precisión que evita sobrerrepresentar esa ley. La indicación escrita de las razones objetivas del rechazo, y la sanción asociada, están predicadas de la institución del sistema financiero y asegurador y de la Superintendencia Financiera [8]. En el escenario base FinanCali no forma parte de ese sistema. La prohibición de decidir solo con el reporte negativo sí le aplica; el deber documental de explicar el rechazo, tal como esa frase lo redacta, no es su gancho principal. La explicación del score queda entonces repartida entre MEASURE 2.9, el numeral VII de la Circular 002 y el principio de transparencia de la Ley 1581, ninguno de los cuales define el artefacto que el solicitante recibe. Ese residuo es B3.

Los marcos voluntarios cubren los resultados de confianza que la circular y la ley no especifican. El AI RMF 1.0 pide gobernar el riesgo de IA, caracterizar impactos sobre personas y grupos, explicar el modelo, examinar el riesgo de privacidad, evaluar equidad y sesgo, evaluar seguridad y resiliencia, y seguir los riesgos en el tiempo [2]. ISO/IEC 42001 ofrece el sistema de gestión para convertir esos resultados en política, roles, evaluación de impacto, datos para la IA, ciclo de vida y relación con proveedores [3]. ISO/IEC 23894 orienta el proceso de identificar, analizar, evaluar y tratar el riesgo de IA, sin ser un sistema certificable ni un catálogo de controles de crédito [4]. Los tres fueron recomendados en el Taller 1 precisamente con esa función. Siguen siendo voluntarios. Atender E1, E2 y la parte de medición de E3 no los convierte en obligaciones de la Superintendencia de Industria y Comercio.

Dos referentes del panorama orientan y no atienden el caso como deber. El CONPES 4144 de 2025 organiza la política nacional en seis ejes, entre ellos ética y gobernanza, datos e infraestructura, y mitigación de riesgos para evitar inequidades y vulneraciones de derechos, con horizonte 2025-2030 [5]. Reconoce a escala nacional el tipo de problema de E1 y E3. No impone a FinanCali un control auditable sobre este score. El Reglamento (UE)

2024/1689 tampoco se aplica a una operación exclusiva en Colombia. Su Anexo III, punto 5, letra b, clasifica como de alto riesgo los sistemas destinados a evaluar la solvencia de personas físicas o a establecer su calificación crediticia, con la excepción de la detección de fraude financiero [9]. El scoring de FinanCali cae en la regla y no en la excepción. El apartado 3 del artículo 6 impide salir de esa clasificación cuando el sistema elabora perfiles de personas naturales, y evaluar solvencia a partir de ingresos, endeudamiento y comportamiento de pago es esa elaboración de perfiles. El reglamento funciona como contraste: un régimen de alto riesgo pediría gestión del riesgo, gobernanza de datos, documentación técnica, registros, transparencia, supervisión humana, exactitud, robustez y ciberseguridad. Muestra, de nuevo, que el CSF solo ocuparía la última de esas piezas. No cubre a FinanCali mientras el sistema no entre en su ámbito territorial.

Queda fuera de esta lista, de propósito, la información al consumidor sobre las condiciones de la financiación. En el escenario base esa carga proviene de la Ley 1480 de 2011 y del Decreto 1074 de 2015, y ya está identificada en el Taller 1. No es un control de seguridad ni de gobernanza del modelo. Tratarla como brecha del CSF confundiría el cumplimiento comercial de la operación de crédito con la protección del sistema de IA. El Estatuto Orgánico del Sistema Financiero y la Ley 1328 de 2009 siguen condicionados al cambio de escenario y no se usan aquí como cobertura.

4.4. Brechas que permanecen sin cobertura adecuada

Las brechas de esta sección no se resuelven con declarar adoptados el CSF 2.0 y el conjunto normativo del Taller 1. Cada una tiene un referente cercano, y ese referente se detiene antes de la decisión que protege a las personas de este flujo.

B1. Pruebas de ataques que usan el modelo, no solo la plataforma

Un solicitante, o quien controle un lote de datos de entrenamiento, puede mover el score sin vulnerar la confidencialidad en el sentido de PR.DS. En un modelo tabular en producción los caminos relevantes son el envenenamiento del lote de entrenamiento, la evasión por manipulación de variables que la API acepta como legítimas, la extracción del modelo a través del servicio interno y la inferencia de pertenencia sobre las solicitudes conservadas. El CSF detecta acceso indebido, adulteración y anomalías de plataforma. MEASURE 2.7 pide evaluar y documentar la seguridad y la resiliencia del sistema de IA, y se queda en ese resultado [2]. Ni el AI RMF 1.0, ni ISO/IEC 42001, ni ISO/IEC 23894, ni la Circular 002 describen esas clases de ataque ni un ensayo para un modelo de boosting usado como umbral de aprobación automática.

La aproximación especializada existe y no forma parte del conjunto del Taller 1: la taxonomía de NIST AI 100-2e2025 y la base de tácticas y técnicas MITRE ATLAS [10] [11]. La implicación es concreta. FinanCali puede cerrar un perfil del CSF y una medición del AI RMF y no saber si cruzar el umbral de aprobación automática es inducible desde el formulario, o si el conjunto histórico conservado para auditoría permite reconstruir si una persona estuvo en el entrenamiento. Con cientos de decisiones al día y colas automáticas en los extremos, ese ataque desplaza decisiones de crédito, no solo registros.

B2. Criterio de equidad del crédito de consumo

MEASURE 2.11 ordena evaluar la equidad y el sesgo y documentar el resultado. La nota 7 de la Circular 002 incluye el sesgo humano entre las contingencias que el sistema de riesgos debe considerar. Ninguno de los dos dice qué grupos comparar, qué métrica usar ni qué disparidad es inaceptable en crédito de consumo en Colombia. No hay una ley horizontal de IA que lo haga: el Taller 1 dejó constancia de que el proyecto de ley general se archivó y de que, a la fecha de ese panorama, no había un estatuto horizontal vigente. El CONPES 4144 anuncia la mitigación de inequidades como eje de política y no sustituye ese estatuto [5].

La dificultad es mayor porque la Ley 2157 empuja en sentido contrario al de una prohibición simple de variables socioeconómicas. Exige valorar el incumplimiento junto con otros factores técnicamente relevantes para el estudio de riesgo [8]. Ingresos, antigüedad laboral y endeudamiento son exactamente esos factores, y son a la vez proxies del perfil socioeconómico de la población afectada. Un estudio de impacto de privacidad puede quedar aprobado y el modelo puede seguir concentrando rechazos automáticos en un grupo, sin que ningún referente analizado declare ese resultado inadmisible. La decisión que falta es un protocolo de este producto: grupos de comparación, métrica, disparidad material y consecuencia sobre las decisiones automáticas. La adopta FinanCali y la documenta. Ningún marco de los ya seleccionados la adopta por ella.

B3. Explicación utilizable por el solicitante y por el analista

MEASURE 2.9 cubre la explicación como característica del modelo. El numeral VII de la Circular 002 y la Ley 1581 cubren la información sobre el tratamiento. Falta el artefacto. No está definido si el solicitante recibe los factores que empujaron su score, si se le debe una alternativa de cambio de resultado, ni qué debe ver el analista de la franja intermedia para poder apartarse de un boosting que no es una regla legible. Como se indicó en E7, la frase de la Ley 1266 que ordena indicar por escrito las razones objetivas del rechazo está dirigida a las entidades del sistema financiero y asegurador [8]. En el escenario base no cierra este hueco.

La implicación se concentra donde el caso retiró a la persona: el rechazo automático. Es la decisión menos explicada y la que el solicitante enfrenta solo, por la aplicación. Hace falta una política de códigos de razón limitada a las variables ya documentadas, distinta para el solicitante y para el analista, y contrastada contra el modelo para que el código no sea una plantilla ajena al score. Esa política es trabajo de explicación aplicada a este motor, no una subcategoría adicional del CSF.

B4. Regla de supervisión de las decisiones automáticas

El caso ya describe un analista en la franja intermedia y un respaldo manual si el servicio no responde. Ese es un hecho operativo. No demuestra que la supervisión sea efectiva. El AI RMF y la ISO/IEC 42001 piden que el papel humano quede definido en el contexto de uso [2] [3]. No fijan el muestreo de las colas de aprobación y rechazo, la autoridad de revocatoria, el tiempo por caso ni un control del sesgo de automatización del analista que recibe un score ya calculado. FinanCali evalúa cientos de solicitudes al día con una planta de unos 50 empleados y sin rol de gobernanza de IA.

La implicación es que la franja intermedia puede exhibirse como supervisión humana mientras la masa de decisiones, la de los extremos, no se revisa nunca. El riesgo del diseño semiautónomo está en la zona de la que se retiró al analista, no en la zona en la que se lo dejó. La regla que falta es operativa: muestra de ambas colas, revocatoria registrada y condición de parada cuando la cola del analista supere la capacidad. Adoptar un marco más no la escribe.

B5. Retención para auditoría y vigencia del dato negativo

El caso conserva solicitudes, variables y score para consulta y auditoría. El parágrafo 3 del artículo 13 de la Ley 1266 exige la actualización simultánea de la medición asociada al dato negativo cuando este se retira [8]. El CSF, aplicado a esa retención, protege la integridad del registro y favorece su conservación. El AI RMF no codifica la regla colombiana de permanencia. Ninguno de los dos resuelve el choque: el expediente que demuestra cómo se decidió un crédito puede convertirse en la copia interna de un dato que el operador ya debía haber sacado de consulta, si esas variables se reutilizan después.

La implicación es de diseño del pipeline, no de política general de backups. Conviene separar el registro histórico de la decisión —qué se decidió, en qué fecha, con qué base y por cuánto tiempo se guarda— de las variables que deben refrescarse o suprimirse cuando la central retire el dato negativo. Reescribir en silencio el score ya emitido destruiría la auditoría; seguir alimentando decisiones nuevas con la variable vencida eludiría la permanencia. Esa partición no está en los referentes analizados.

B6. Partición entre entrenamiento e inferencia

El numeral VI de la Circular 002 señala la privacidad diferencial como vía matemática para hacer analítica sin revelar a la persona que aportó el dato [6]. La inferencia de FinanCali no puede funcionar así: el score tiene que ser sobre el solicitante identificado, con sus ingresos, su endeudamiento y su reporte. Aplicar la técnica a la decisión individual inutiliza el producto. No aplicarla en ninguna etapa deja el numeral VI sin respuesta dentro del estudio de impacto. MEASURE 2.10 pide examinar el riesgo de privacidad y no resuelve en qué etapa [2].

La implicación es una decisión de ingeniería de privacidad de este flujo. Las técnicas de minimización y, cuando el presupuesto de privacidad lo permita, la privacidad diferencial corresponden al entrenamiento y a la evaluación del lote. El registro identificado se usa en la inferencia, con finalidad limitada al estudio de esa solicitud y con el control de acceso que el CSF sí sabe expresar. El estudio de impacto del numeral IV es el lugar donde esa partición debe quedar escrita. Sin ella, el estudio puede copiar el numeral VI y no describir el sistema que está en producción.

B7. Validación de un modelo que FinanCali no entrenó

Esta brecha está condicionada a la rama que el Taller 1 dejó abierta: que el modelo se adquiera a un proveedor. Si eso ocurre, MEASURE 2.9 y MEASURE 2.11 suponen que la organización puede explicar y evaluar. El proveedor puede no entregar el conjunto de entrenamiento. La Ley 1581 mantiene a FinanCali como responsable si ella define la finalidad, y exige formalizar al proveedor como encargado cuando trate datos por su cuenta. La Circular Externa 002 de 2025 queda, como ya se clasificó en el Taller 1, en el supuesto condicionado de transferencia de tecnología con datos personales. GV.SC cubre las expectativas de ciberseguridad del proveedor y no la validación de equidad. Ninguno de esos referentes crea, por sí solo, el derecho a auditar un modelo ajeno.

La implicación es que comprar el modelo puede sacar de la vista de FinanCali las brechas B1, B2 y B3 sin sacar de ella el deber. La aproximación especializada es contractual y previa a la entrada en producción: muestra de validación, interfaz de códigos de razón, aviso de reentrenamiento y restricción para que el proveedor no use los solicitantes de FinanCali como entrenamiento de otros clientes sin base jurídica. Si el proveedor o la nube están fuera de Colombia, el análisis de transferencia internacional ya identificado en el Taller 1 es condición previa de ese contrato, no su reemplazo. Si el modelo sigue siendo interno, B7 no se activa.

4.5. Por qué hacen falta los dos referentes

CAPA DE PLATAFORMA · NIST CSF 2.0 · NECESARIA

Activos, accesos, integridad y confidencialidad, detección de eventos de ciberseguridad, respuesta y recuperación del servicio, expectativas de ciberseguridad hacia terceros.

CAPA DE LA DECISIÓN Y DEL CICLO DE VIDA · NORMAS Y MARCOS DE IA DEL TALLER 1 · NECESARIA

Proporcionalidad, calidad, estudio de impacto, habeas data del score, gobernanza del modelo, medición de deriva y sesgo, explicación y supervisión humana como resultados.

DECISIONES QUE NINGUNA DE LAS DOS CAPAS ESPECIFICA · B1 A B7

Ensayos adversariales del modelo tabular, criterio de equidad, códigos de razón, regla de muestreo de las colas automáticas, partición de la retención, partición entrenamiento/inferencia y, si el modelo se compra, derechos de validación.

El CSF 2.0 es necesario porque el scoring también es un sistema digital con los vacíos de madurez ya descritos: inventario parcial, accesos privilegiados, ausencia de monitoreo de la API, ausencia de respuesta y de retorno a una versión anterior, y dependencia de centrales, nube y eventuales proveedores. El AI RMF no levanta el inventario de esos activos ni conduce la atención del incidente de la API. El texto del CSF 2.0 hace este reparto: el riesgo de ciberseguridad permanece en el CSF y los demás riesgos de la IA se tratan junto a él, no en su lugar [1]. Quedarse solo con las normas de IA dejaría desprotegido el canal por el que el score se produce y se entrega.

Las normas y los marcos de IA son necesarios porque una plataforma bien protegida puede emitir un score ilegítimo. El daño propio de este caso no es únicamente la filtración. Es una decisión, a menudo automática, sobre el acceso al crédito de una persona natural, construida con datos personales, financieros y de centrales. Ese daño es el que atienden la Circular 002 de 2024, la Ley 1266 modificada por la Ley 2157 y las funciones de medición del AI RMF. DE.CM no va a alertar un modelo que, con el servicio disponible y la API íntegra, concentre rechazos en un perfil socioeconómico: eso no es un evento adverso de ciberseguridad. Por eso la ausencia de monitoreo del comportamiento del modelo, documentada en el Taller 1, sobrevive a la adopción del CSF. En el nivel del resultado, se atiende cuando se añade un marco de riesgo de IA.

La conjunción tampoco equivale a la protección completa del sistema. B1 a B7 quedan en el cruce de tres exigencias: un resultado de ciberseguridad (el dato sigue íntegro y el servicio se recupera), un deber legal (no decidir solo con el reporte negativo; evaluar el impacto de privacidad) y un resultado voluntario (medir la equidad y explicar el modelo). Ninguna de las tres escribe el umbral de disparidad, el código de razón, la muestra de las decisiones automáticas, la partición de la retención ni el ensayo adversarial. Dejar esas decisiones implícitas permitiría presentar la adopción de los dos referentes como cobertura total del scoring. No lo es.

La capacidad de FinanCali acota la implicación práctica. El Punto 2 ya descartó ISO/IEC 27001 y COBIT para esta etapa por el peso de formalización, y conservó CIS Controls como traducción técnica posterior. El mismo criterio sirve aquí. No hace falta un tercer marco organizacional para cerrar B1 a B7. Hace falta un orden de atención compatible con un equipo pequeño y con deberes que ya son exigibles. Primero, el estudio de impacto de privacidad, porque la Circular 002 lo pide antes del diseño y el sistema ya opera, e incluir dentro de ese estudio la partición de B6. Segundo, la partición de retención de B5, porque choca con un deber vigente de habeas data y con una práctica de conservación que el caso ya declaró. Tercero, la regla de supervisión de B4, porque el daño se concentra en las decisiones de las que se retiró al analista. Después, los códigos de razón de B3, el protocolo de equidad de B2 y los ensayos de B1. B7 se antepone a todas las anteriores en la rama, y solo en la rama, en que el modelo se compre: sin visibilidad del modelo, las mediciones que el AI RMF pide no pueden ejecutarse. Las dos primeras son deberes ya aplicables. De la tercera en adelante está la capa especializada que los referentes analizados dejan abierta.

4.6. Cierre

NIST CSF 2.0 organiza la ciberseguridad del flujo de scoring y responde a las brechas de plataforma identificadas en FinanCali. No cubre la gobernanza del modelo, el monitoreo de su comportamiento, la equidad de la decisión automática, la explicación del score, el juicio de proporcionalidad y el impacto de privacidad, la efectividad de la supervisión humana ni las reglas de habeas data que condicionan la lógica y la vigencia de la medición. Esos elementos quedan atendidos, con el alcance precisado en la Tabla 2, por la Circular Externa 002 de 2024, la Ley 1581 de 2012, la Ley 1266 de 2008 modificada por la Ley 2157 de 2021, el NIST AI RMF 1.0, la ISO/IEC 42001 y la ISO/IEC 23894. El CONPES 4144 y el Reglamento europeo de IA orientan ese juicio y no obligan a la operación actual.

Aun reunidos, esos referentes dejan sin especificar siete decisiones de este sistema: los ensayos de ataques propios del modelo, el criterio de equidad, la explicación utilizable, la supervisión de las colas automáticas, la convivencia entre auditoría y retiro del dato negativo, la partición de privacidad entre entrenamiento e inferencia y, si el modelo se adquiere, los derechos para validarlo. Proteger el scoring de FinanCali requiere el marco de ciberseguridad y el marco normativo de IA. Requiere, además, tratar esas siete decisiones como diseño especializado y no como cobertura ya obtenida.

Referencias

1. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29. 26 de febrero de 2024. https://doi.org/10.6028/NIST.CSWP.29
2. National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST.AI.100-1. Enero de 2023. https://doi.org/10.6028/NIST.AI.100-1
3. International Organization for Standardization. ISO/IEC 42001:2023. *Information technology — Artificial intelligence — Management system*.
4. International Organization for Standardization. ISO/IEC 23894:2023. *Information technology — Artificial intelligence — Guidance on risk management*.
5. Departamento Nacional de Planeación. Documento CONPES 4144. *Política Nacional de Inteligencia Artificial*. 14 de febrero de 2025. https://normograma.mintic.gov.co/mintic/compilacion/docs/CONPES_DNP_4144_2025.htm
6. Superintendencia de Industria y Comercio. Circular Externa 002 del 21 de agosto de 2024. *Lineamientos sobre el tratamiento de datos personales en sistemas de inteligencia artificial*. Diario Oficial 52.856. https://normograma.mintic.gov.co/mintic/compilacion/docs/circular_superindustria_0002_2024.htm
7. Congreso de la República de Colombia. Ley Estatutaria 1581 de 2012. *Por la cual se dictan disposiciones generales para la protección de datos personales*.
8. Congreso de la República de Colombia. Ley 2157 de 2021, que modifica la Ley Estatutaria 1266 de 2008. En particular, artículo 13, parágrafo 3, y artículo 10, parágrafos 1 y 2, de la Ley 1266 en el texto modificado. http://www.secretariasenado.gov.co/senado/basedoc/ley_2157_2021.html
9. Unión Europea. Reglamento (UE) 2024/1689 del Parlamento Europeo y del Consejo. Artículo 6, apartados 2 y 3, y Anexo III, punto 5, letra b.
10. National Institute of Standards and Technology. *Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations*. NIST AI 100-2e2025. https://doi.org/10.6028/NIST.AI.100-2e2025
11. MITRE. *ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems*. https://atlas.mitre.org/